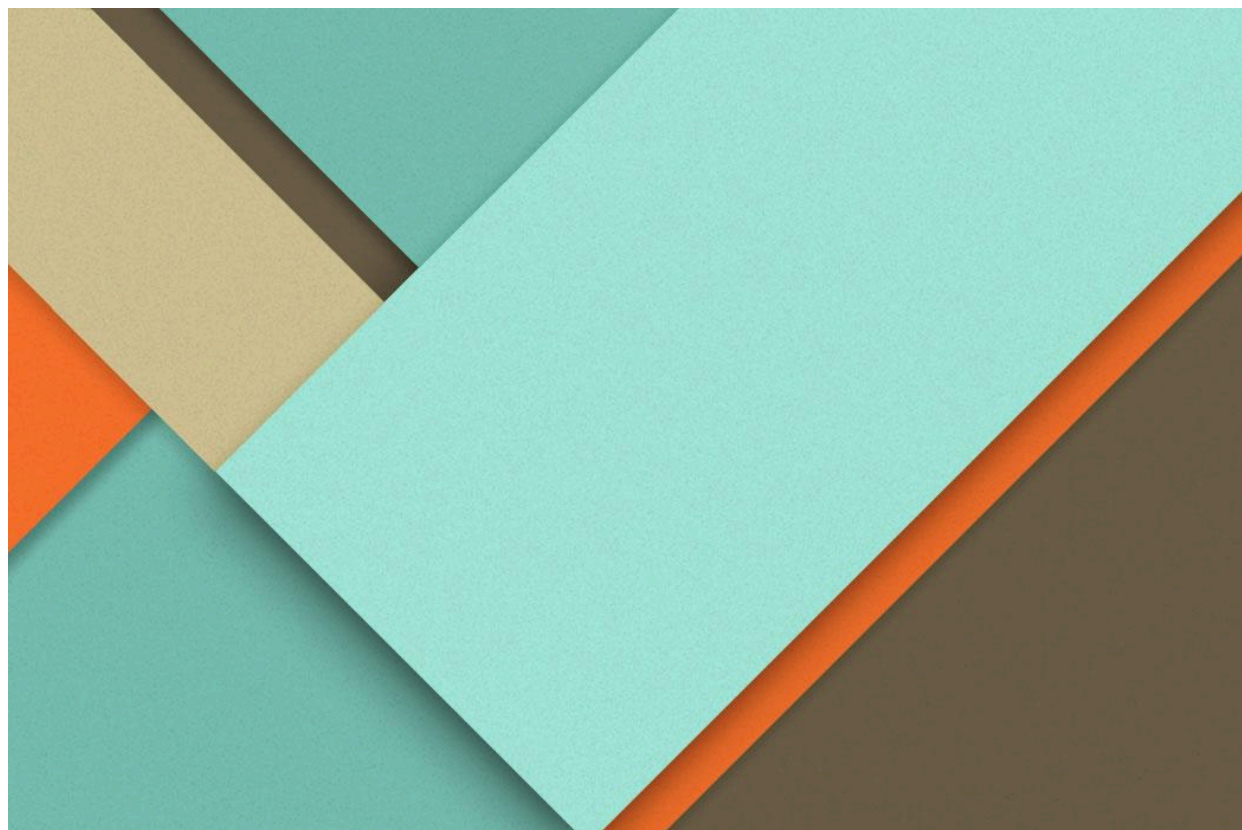




Informe de Incidente de Seguridad

31.01.2025

Luciano Arossa

4Geeks Academy

1. Introducción y Resumen Ejecutivo

Este informe detalla el incidente de seguridad producido sobre el servidor Debian “debian-final-project.ova” de **4Geeks Academy**. El servidor fue proporcionado por 4Geeks Academy a Luciano Arossa, quien realizó la investigación e informe del mismo.

Luego de un exhaustivo análisis forense (**Lease 3. Análisis Forense**) se encontraron los siguientes hallazgos clave:

- ❖ El archivo system.journal muestra que el 8.10.2024 17:40 se realizó un login por protocolo SSH2 en el puerto 45623 (no estándar) desde la dirección IP 192.168.0.134. No se pudo determinar cómo el atacante tuvo acceso a la red local.
- ❖ El archivo sshd_config habilita PasswordAuthentication y PermitRootLogin
- ❖ La configuración wordpress presenta fallos de seguridad importantes:
 - En relación a permisos, wp-config.php tiene habilitados permisos de Lectura, Escritura y Ejecución para todos los usuarios (777).
 - El archivo wp-config.php muestra en texto plano la contraseña de la base de datos. En agregado, el usuario y contraseña tienen una complejidad deficiente (Se encuentran disponibles en las más populares wordlists)
 - Al sumar ambos fallos de seguridad mencionados, se abre la posibilidad de acceder a la base de datos, obteniendo datos y/o acceso como administrador al panel wordpress. Esto facilita crear nuevas vulnerabilidades que no solo afecten al servidor sino también al visitante de la página.
- ❖ Múltiples servicios, incluyendo OpenSSH, se encuentran utilizando una versión vulnerable o no actualizada.
- ❖ El archivo auth.log se encuentra eliminado del directorio /var/log/

En relación a las vulnerabilidades relacionadas a los hallazgos anteriores, se realizaron las siguientes acciones correctivas y preventivas:

Acciones correctivas

- ❖ Actualizar el usuario y contraseña inseguros del administrador de base de datos WordPress. Insertar el hash obtenido de la contraseña en `/var/www/html/wp-config.php`
- ❖ Cambiar los permisos en `/var/www/html/wp-config.php` a 600.

Acciones Preventivas

- ❖ Actualizar servicio SSH y otros que se encuentren desactualizados
- ❖ Deshabilitar PasswordAuthentication y PermitRootLogin en `/etc/ssh/sshd_config`
- ❖ Establecer una política de firewall y contraseñas seguras para mejor prevención

En relación a lo mencionado, el ataque fue realizado sobre SSH debido a credenciales inseguras el 8.10.2024 a las 17:40.

2. Datos generales del Incidente

4Geeks Academy proporcionó el servidor Debian a **Luciano Arossa** para la investigación del Incidente realizada durante el mes de **Enero de 2025**. Luego del análisis e investigación se determinaron los siguientes datos del incidente:

- ❖ Fecha y Hora aproximada del ataque: **Octubre 8 2024 17:40**
- ❖ Tipo de ataque: Vulneración del protocolo **SSH**
- ❖ Vector de ataque: Acceso remoto
- ❖ Analista del incidente: Luciano Arossa (lucianoarossa1@gmail.com)

3. Análisis Forense

- ❖ Versión del servidor Debian: 5.4.x
- ❖ Servicios expuestos: FTP, SSH y HTTP
- ❖ Puertos abiertos: 21, 22 y 80
- ❖ Registros del sistema
 - System.journal muestra un acceso remoto mediante SSH por un puerto alterno (Puerto: 45623).
 - /etc/sv/ssh/ incluye un administrador de SSH alternativo a systemd (Utilizado por defecto en Debian). Sospecha de ser el servicio runit.
 - Auth.log fue eliminado del sistema, indicando posible eliminación de pruebas o entradas fallidas por un ataque de fuerza bruta en protocolo SSH.
- ❖ Vulnerabilidades detectadas
 - Configuración deficiente en archivo sshd_config, wp-config.php, apache2.conf.
 - Vulnerabilidades ante DoS en el servicio vsftpd 3.0.3 (CVE-2021-30047)
 - Vulnerabilidad ante RCE en OpenSSH 9.2 (CVE-2024-6387)

4. Acciones realizadas y recomendaciones

Debido a la información recopilada gracias al análisis forense se tomaron diferentes acciones correctivas y preventivas.

Durante la investigación se encontró un problema de seguridad relacionado a la mala configuración de la aplicación wordpress presente en el servidor APACHE /var/www/html/. La mala configuración es una de las vulnerabilidades más comunes y presente en el OWASP TOP 10, lo cual demuestra la criticalidad de esta misma. En relación a esta vulnerabilidad, se tomó la siguiente medida correctiva:

- ❖ Actualizar el usuario y contraseña inseguros del administrador de base de datos WordPress. Insertar el hash obtenido de la contraseña en /var/www/html/wp-config.php

Otra mala configuración fue encontrada dentro del wordpress, en este caso en relación a la gestión de permisos. El path `/var/www/html/wp-config.php` tiene los permisos configurados para habilitar la lectura, escritura y ejecución para todos los usuarios. Este archivo de wordpress tiene información necesaria para la ejecución de otros archivos, por lo que siguiendo el principio 0 trust se le otorgaron los permisos mínimos para la funcionalidad del sitio web. La siguiente acción correctiva se realizó:

- ❖ Cambiar los permisos en `/var/www/html/wp-config.php` a 600.

En relación con la configuración SSH, se decidió tomar algunas medidas preventivas. Al revisar la configuración SSH, se confirmó la presencia de los términos `PasswordAuthentication`, que permite la conexión SSH mediante contraseña. Esto se considera menos seguro que otras opciones debido a que es susceptible a Fuerza Bruta si las contraseñas son débiles. Deshabilitar `PasswordAuthentication` mejoraría la seguridad pero obligaría a utilizar otros métodos como la autenticación con clave pública.

También se encontró el término `PermitRootLogin`, esto permite el acceso SSH por parte del usuario root. Esto es deficiente en términos de seguridad ya que si, un atacante obtiene la contraseña root, podría tomar control completo del servidor. Las medidas tomadas son las siguientes:

- ❖ Configurar con valor "NO" `PasswordAuthentication` y `PermitRootLogin` en `/etc/ssh/sshd_config`

Como último, algunas recomendaciones y acciones preventivas a tomar son la creación de una política de contraseñas seguras, una política de actualización de servicios y una política de firewall estricta.

Estos cambios fortalecerán el enfoque de seguridad de la organización en relación al servidor debían investigar. Facilita también la prevención y minimización de vectores de ataque, como pueden ser la Fuerza Bruta, el DoS o RCE.

5. Conclusión

En resumen, el análisis forense del servidor Debian "debian-final-project.ova" reveló múltiples vulnerabilidades y malas configuraciones que permitieron el acceso no autorizado a través de SSH el 8 de octubre de 2024 a las 17:40.

El ataque se llevó a cabo explotando credenciales SSH débiles y la configuración insegura del servicio, específicamente la habilitación de PasswordAuthentication y PermitRootLogin. Además, se identificaron vulnerabilidades en la configuración de WordPress, incluyendo permisos excesivos en el archivo wp-config.php y credenciales de base de datos inseguras, lo que podría haber escalado los privilegios del atacante y comprometido la integridad de la aplicación web. La eliminación del archivo auth.log sugiere un intento de ocultar la actividad maliciosa, lo que refuerza la naturaleza maliciosa del incidente.

Este incidente subraya la importancia de realizar auditorías de seguridad periódicas, mantener el software actualizado y seguir las mejores prácticas de seguridad para proteger los sistemas de información. La combinación de vulnerabilidades encontradas resalta la necesidad de un enfoque de seguridad en capas que abarque tanto el sistema operativo como las aplicaciones web. Se recomienda realizar un análisis de riesgos exhaustivo para identificar y mitigar otras posibles vulnerabilidades y asegurar la protección continua del servidor Debian. Finalmente, se insta a la organización a adoptar una cultura de seguridad proactiva que priorice la prevención, la detección temprana y la respuesta rápida a incidentes de seguridad.